

A Microcosm of the interactions in Open Source projects

Saturday, March 30, 2024

Originally a thread on Twitter about the xz/liblzma vulnerability, when I finished typing it, I realized I had a real world slice of Open Source interaction that deserved more attention.



There will be lots of analysis of the xz/liblzma vulnerability. However, I've found most skip over the first step of the attack:

0. Original maintainer burns out, and only the attacker offers to help (so attacker inherits trust built up by the original

maintainer)

Amazingly someone found an archive with an [email thread that captured the state of the world](#) just as this step 0 was taking place. Let's read their words.

First, we start with a reasonable request asked reasonably. The question forces the maintainer to address his "failings". I use "failings" in quotes here because a. the maintainer doesn't *actually* owe anything here so he hasn't actually failed and b. I know exactly how this feels. It feels terrible to let down your "community".

"Is XZ for Java still maintained? I asked a question here a week ago and have not heard back." - <https://www.mail-archive.com/xz-devel@tukaani.org/msg00562.html>

The maintainer acknowledges he's "behind" and is struggling to keep up. This is a cry in pain. This is a cry for help. Help will not be coming in this thread.

"Yes, by some definition at least, like if someone reports a bug it will get fixed. Development of new features definitely isn't very active. :-(" - <https://www.mail-archive.com/xz-devel@tukaani.org/msg00563.html>

Oh! Here we are introduced to our xz/liblzma attacker, in the very same message. This is not the help you were hoping for.

“Jia Tan has helped me ... and he might have a bigger role in the future ... It’s clear that my resources are too limited ... so something has to change in the long term.” - <https://www.mail-archive.com/xz-devel@tukaani.org/msg00563.html>

Instead, an unhelpful consumer says unhelpful things. This is exactly where these types of email threads go.

“Progress will not happen until there is new maintainer. ... The current maintainer lost interest or doesn’t care to maintain anymore. It is sad to see for a repo like this.” - <https://www.mail-archive.com/xz-devel@tukaani.org/msg00566.html>

Aside: Given that the xz/liblzma vulnerability looks like a purposeful attack by “Jia Tan” should “Jigar Kumar” be considered an accomplice by actively encouraging the original maintainer to give up? Not sure? We’ll see this unhelpful consumer “Jigar Kumar” again soon.

Inevitably the maintainer tries to defend himself. Maintainers handle the stress of burn out differently. I tend to get angry which ends up coming across snarky. However, this reaction is heart breaking.

“I haven’t lost interest but my ability to care has been fairly limited mostly due to longterm mental health issues but also due to some other things.” - <https://www.mail-archive.com/xz-devel@tukaani.org/msg00567.html>

...and then the maintainer also reminds everybody how the world’s software is built now.

“It’s also good to keep in mind that this is an unpaid hobby project” - <https://www.mail-archive.com/xz-devel@tukaani.org/msg00567.html>

A week later, the unhelpful consumer returns. **A WEEK LATER.**

“You ignore the many patches bit rotting away on this mailing list. Right now you choke your repo. Why wait until 5.4.0 to change maintainer? Why delay what your repo needs?” - <https://www.mail-archive.com/xz-devel@tukaani.org/msg00568.html>

What purpose does this serve? I can’t tell you how angry this makes me feel for this maintainer.

Then our reasonable requestor that started this email thread decides now is a good time to make demands as well.

“I am sorry about your mental health issues, but its important to be aware of your own limits. I get that this is a hobby project for all contributors, but the community desires more” - <https://www.mail-archive.com/xz-devel@tukaani.org/msg00569.html>

Read that last sentence again, “the community desires more”. Consumers must be fed. The needs of the maintainer, of which there are clearly a few important ones, are ignored.

Our no-longer-reasonable requestor also offers a suggestions. Notice there is no offer to actually help.

“Why not pass on maintainership for XZ for C so you can give XZ for Java more attention? Or pass on XZ for Java to someone else to focus on XZ for C? Trying to maintain both means that neither are maintained well.” - <https://www.mail-archive.com/xz-devel@tukaani.org/msg00569.html>

So, the maintainer has to explain the reality.

“Finding a co-maintainer or passing the projects completely to someone else has been in my mind a long time but it’s not a trivial thing to do. For example, someone would need to have the skills, time, and enough long-term interest specifically for this.” - <https://www.mail-archive.com/xz-devel@tukaani.org/msg00571.html>

It takes skill and knowledge to write software. And while many skills and some knowledge will transfer, working on a new software project inevitably requires developing new skills and more knowledge.

Software developers are not fungible cogs that you can swap in and out at will.

The email thread ends with the complaining consumers offering no help while continuing to make demands. Only the attacker is left.

“Jia Tan may have a bigger role in the project in the future. He has been helping a lot off-list and is practically a co-maintainer

already. :-)" - <https://www.mail-archive.com/xz-devel@tukaani.org/msg00571.html>

This thread is a microcosm of the interactions in Open Source projects. Consumers make demands (some polite, some not-so-polite) of one maintainer (rarely two) that does everything.

Make no mistake. This is the way it works.

[It needs to change.](#)



After a couple hours of experimentation, I think I...

What could be done to support Open Source maintainers?

